

SIMATS ENGINEERING
ASSESSMENT TOOL 2 – INDUSTRY PROBLEM TASK

Course Name: Ethical Hacking	Code: ITA1404	CO: CO5
Duration: 90 min Date:	Total Marks:	Reg. No / Name : S Venkata Abhishek(192311053)

Question 1 – Windows Domain Network and Lateral Movement

Given Data

- Total systems = 150
- Systems allowing anonymous enumeration = 45%
- Systems susceptible to SMB lateral movement among those = 60%
- Attempts from each compromised system = 3
- Probability of success per attempt = 0.3

Step 1: Initial-stage compromise

Number of systems allowing anonymous enumeration:

$$[150 \times 0.45 = 67.5]$$

Therefore, the expected initial exposure is approximately **68 systems**.

Among these, 60% are susceptible to SMB-based lateral movement:

$$[67.5 \times 0.60 = 40.5]$$

Thus, approximately **40–41 systems** are exposed to the lateral-movement condition.

Step 2: Second-stage lateral movement

Each compromised system makes 3 attempts, with a success probability of 0.3.

Expected successful lateral-movement compromises per system:

$$[3 \times 0.3 = 0.9]$$

Therefore:

$$[40.5 \times 0.9 = 36.45]$$

The expected second-stage spread is approximately **36 additional successful compromises**.

The expected total number of affected systems is:

$$[67.5 + 36.45 = 103.9]$$

Percentage of the network:

$$[\frac{103.95}{150} \times 100 = 69.3\%]$$

Risk Evaluation

The calculated spread is approximately **69.3%**, which is slightly below the specified large-scale compromise threshold of 70%.

Priority Mitigation

Misconfigured shared folders/weak shares should receive the highest immediate priority, because they directly facilitate unauthorized access and SMB-based lateral movement. NULL sessions should also be disabled because anonymous enumeration provides attackers with useful information about users, shares, and systems.

RPC exposure should be reduced by restricting unnecessary RPC services through firewalls and access-control policies.

Recommended Controls

1. Disable unnecessary NULL/anonymous sessions.
2. Restrict SMB access using host-based and network firewalls.
3. Correct permissions on shared folders using least privilege.
4. Disable unnecessary RPC services and restrict RPC to trusted hosts.
5. Monitor abnormal SMB authentication and lateral-movement activity.
6. Segment critical Windows systems into separate network zones.

Conclusion: The network is at **high risk**, with an estimated 69.3% exposure after two stages. Weak shares and SMB lateral movement should be addressed immediately.

Question 2 – RPC Exposure and Exploitation

Given Data

- Total systems = 120
- Systems exposing RPC = 70
- Vulnerable systems = 40% of RPC-exposed systems
- Exploitation success probability = 0.5
- Detection probability per exploitation attempt = 0.25

Step 1: Number of vulnerable systems

$$[70 \times 0.40 = 28]$$

Therefore, **28 systems** are expected to be vulnerable to known exploits.

Step 2: Expected successful compromises

Each vulnerable system has a 0.5 probability of successful exploitation.

$$[28 \times 0.5 = 14]$$

Therefore, the expected number of successfully compromised systems is:

$$[\boxed{14}]$$

Step 3: Expected detection alerts

The detection probability for each exploitation attempt is 0.25.

$$[28 \times 0.25 = 7]$$

Therefore, the expected number of detection alerts is:

$$[\boxed{7}]$$

This means an attacker attempting exploitation across all vulnerable systems can expect approximately **7 detection alerts**.

Stealth Analysis

An attacker seeking to remain stealthy faces a significant trade-off:

- Expected vulnerable targets = 28
- Expected successful compromises = 14
- Expected alerts = 7

Although exploitation can provide substantial access, generating approximately seven alerts creates a meaningful probability of detection and incident response.

Therefore, a stealth-focused attacker would likely avoid indiscriminate exploitation and may instead seek lower-noise attack paths such as exploiting misconfigurations, compromised credentials, or already exposed legitimate services.

Recommended Defensive Measures

- Restrict RPC exposure to only authorized systems.
- Patch vulnerable RPC services.
- Apply network segmentation.
- Monitor unusual RPC activity.
- Correlate IDS alerts with endpoint and authentication logs.
- Apply least-privilege access controls.

Conclusion: RPC exploitation offers an expected **14 successful compromises**, but approximately **7 alerts** could be generated. Therefore, aggressive exploitation is relatively risky for a stealth-oriented attacker.

Question 3 – Cloud Linux Server and Weak File Permissions

Given Data

The probabilities of vulnerability for four independent services are:

$$[P_1=0.3, \quad P_2=0.2, \quad P_3=0.25, \quad P_4=0.15]$$

Probability of privilege escalation through weak file permissions:

$$[P_E=0.5]$$

Step 1: Probability that no service is vulnerable

For each service, the probability of not being vulnerable is:

$$[1-0.3=0.7]$$

$$[1-0.2=0.8]$$

$$[1-0.25=0.75]$$

$$[1-0.15=0.85]$$

Since the services are independent:

$$[P(\text{none vulnerable}) = 0.7 \times 0.8 \times 0.75 \times 0.85]$$

$$[=0.357]$$

Step 2: Probability that at least one service is vulnerable

$$[P(\text{at least one}) = 1 - P(\text{none})]$$

$$[=1-0.357]$$

$$[=\boxed{0.643}]$$

Therefore, the probability of at least one vulnerable service is:

$$[\boxed{64.3\%}]$$

Step 3: Probability of full system compromise

Assuming successful initial service exploitation provides initial access and weak permissions independently provide a 0.5 probability of privilege escalation:

$$[P(\text{full compromise}) = 0.643 \times 0.5]$$

$$[\boxed{0.3215}]$$

Therefore:

$$[\{32.15\% \}]$$

is the estimated probability of full system compromise.

Risk Analysis

The probability of initial service exposure is **64.3%**, which is substantial. Even though weak file permissions have a significant effect on privilege escalation, fixing permissions alone would reduce the modeled full-compromise probability from 32.15% to approximately zero **under this simplified two-step model**, but it would not remove the high probability of initial unauthorized access.

Attackers could still:

- Access vulnerable network services.
- Exploit application vulnerabilities.
- Establish limited user-level access.
- Search for credentials and secrets.
- Exploit other local or cloud configuration weaknesses.

Recommended Mitigation

1. Patch and harden all internet-facing services.
2. Disable unnecessary services.
3. Apply least-privilege file permissions.
4. Prevent unauthorized modification of sensitive files.
5. Use security groups/firewalls to restrict exposed ports.
6. Monitor authentication and privilege-escalation events.

Conclusion: At least one service has a **64.3% probability of being vulnerable**, while the modeled probability of full compromise is **32.15%**. Strengthening file permissions is important, but it must be combined with service hardening because the initial attack surface remains high.

Question 4 – NFS Unauthorized Access

Given Data

Unauthorized-access probabilities from three subnets are:

$$[P_1=0.4, \quad P_2=0.3, \quad P_3=0.2]$$

Probability of privilege escalation to root after NFS access:

$$[P_R=0.7]$$

Step 1: Probability that no subnet gains unauthorized access

The probabilities of failure are:

$$[1-0.4=0.6]$$

$$[1-0.3=0.7]$$

$$[1-0.2=0.8]$$

Therefore:

$$[P(\text{no unauthorized access}) = 0.6 \times 0.7 \times 0.8]$$

$$[=0.336]$$

Step 2: Probability that at least one subnet gains access

$$[P(\text{at least one access}) = 1 - 0.336]$$

$$[=\boxed{0.664}]$$

Therefore, the probability of unauthorized NFS access is:

$$[\boxed{66.4\%}]$$

Step 3: Probability of complete compromise

Once access is obtained, the probability of root privilege escalation is 0.7.

$$[P(\text{complete compromise}) = 0.664 \times 0.7]$$

$$[=\boxed{0.4648}]$$

Therefore:

$$[\boxed{46.48\%}]$$

is the estimated probability of complete system compromise.

Single-Subnet Mitigation Analysis

If NFS access is restricted to only one subnet, the resulting complete-compromise probabilities depend on the selected subnet.

For subnet 1:

$$[0.4 \times 0.7 = 0.28 = 28\%]$$

For subnet 2:

$$[0.3 \times 0.7 = 0.21 = 21\%]$$

For subnet 3:

$$[0.2 \times 0.7 = 0.14 = 14\%]$$

Therefore, restricting access to the third, lowest-risk subnet would reduce the modeled complete-compromise probability from:

$$[46.48\% \rightarrow 14\%]$$

This represents an approximate reduction of:

$$\left[\frac{46.48 - 14}{46.48} \times 100 \right] \approx 69.9\%$$

Recommendation

Restricting NFS access to a single trusted subnet is an effective network-level mitigation, provided that the selected subnet is properly secured.

Additional controls should include:

- Restricting NFS through firewall rules.
- Using authenticated and encrypted NFS configurations where appropriate.
- Applying least-privilege export permissions.
- Preventing unrestricted root access through NFS.
- Monitoring NFS authentication and access logs.

Conclusion: The current configuration has a **66.4% probability of unauthorized access** and a **46.48% probability of complete compromise**. Restricting NFS to a carefully controlled subnet can substantially reduce the attack surface.

Question 5 – SQL Injection and Database Data Exposure

Given Data

- Total user records = 50,000
- Sensitive records = 30%
- Extraction rate = 500 records/second
- Detection/blocking time = 40 seconds

Step 1: Number of records extracted

$$500 \times 40$$

$$= 20,000$$

Therefore, the attacker can potentially extract **20,000 records** before being blocked.

Step 2: Percentage of total database compromised

$$\frac{20,000}{50,000} \times 100$$

$$= 40\%$$

Therefore, approximately **40% of the entire database** could be exposed.

Step 3: Number of sensitive records exposed

Sensitive records constitute 30% of the database:

$$50,000 \times 0.30 = 15,000$$

Assuming the extracted records have the same sensitive-data distribution as the overall database:

$$20,000 \times 0.30 = 6,000$$

Therefore, approximately:

$$6,000$$

sensitive records could be exposed.

Severity Evaluation

The breach should be classified as **high severity** because:

- 20,000 records can potentially be extracted.
- 40% of the database may be compromised.
- Approximately 6,000 sensitive records may be exposed.
- SQL injection provides direct access to application database information.
- The attack can occur rapidly before detection.

Although the firewall detects the attack after 40 seconds, the extraction rate of 500 records per second allows a large quantity of data to leave the database before blocking occurs.

Is the Existing Detection Mechanism Sufficient?

No. Detection and blocking after 40 seconds alone is not sufficient protection for critical data.

The application should implement preventive controls such as:

1. Parameterized SQL queries and prepared statements.
2. Strict server-side input validation.
3. Least-privilege database accounts.
4. Web application firewall rules for SQL injection.
5. Database activity monitoring.
6. Rate limiting and anomaly detection.
7. Encryption and appropriate protection of sensitive information.
8. Regular vulnerability scanning and penetration testing in authorized environments.

Conclusion: The existing mechanism limits the attack but does not prevent substantial data loss. A potential exposure of **20,000 records (40%)**, including approximately **6,000 sensitive records**, demonstrates that preventive SQL-injection controls are essential.

Overall Security Assessment

Question	Key Result	Risk Assessment
Q1 – Windows lateral movement	~67.5 initial + ~36.45 second-stage = ~104 affected	High
Q2 – RPC exploitation	14 expected compromises; 7 expected alerts	High
Q3 – Linux cloud server	64.3% initial vulnerability; 32.15% full compromise	High
Q4 – NFS	66.4% unauthorized access; 46.48% complete compromise	High
Q5 – SQL Injection	20,000 records / 40%; ~6,000 sensitive	Critical/High

Security Tools and Engineering Concepts

For an authorized security assessment, the following tools and concepts can support the analysis:

- **Nmap:** Service and port discovery.
- **Nessus/OpenVAS:** Vulnerability assessment.
- **enum4linux:** Authorized Windows/SMB enumeration.
- **smbclient:** Testing SMB share accessibility.
- **Wireshark:** Network traffic analysis.
- **Burp Suite:** Authorized web-application security testing.
- **Linux permission auditing:** Identification of excessive file permissions.
- **SIEM/IDS:** Detection and correlation of exploitation attempts.

These tools should only be used against systems for which explicit authorization has been provided.

Final Conclusion

The calculations demonstrate that seemingly moderate individual vulnerabilities can combine to create substantial enterprise risk. Anonymous enumeration can facilitate SMB lateral movement, exposed RPC services can provide additional attack opportunities, vulnerable Linux services can provide initial access, weak NFS configurations can enable unauthorized access and privilege escalation, and SQL injection can result in rapid large-scale data extraction.

The most effective security strategy is therefore **defense in depth**: eliminate unnecessary exposure, apply least privilege, patch vulnerable services, segment networks, secure file and share permissions, deploy preventive application controls, and continuously monitor for anomalous activity.